



AuthiChain Production Security Checklist

Quick Reference Guide for Production Deployment



Pre-Deployment Security Checklist

Environment Variables

- ☐ All 34+ environment variables configured in Vercel
- ☐ `NEXTAUTH_SECRET` generated with `openssl rand -base64 32`
- ☐ `NEXTAUTH_URL` set to production domain (HTTPS)
- ☐ Stripe keys switched from TEST (`sk_test_`) to LIVE (`sk_live_`)
- ☐ All Stripe price IDs created in LIVE mode
- ☐ Database URL points to production database
- ☐ New production wallet private key generated
- ☐ NFT.Storage API key is active
- ☐ Cloudflare R2 credentials configured
- ☐ `NODE_ENV` set to `production`
- ☐ No test/development values in production env

Code Security

- ☐ All API routes use security middleware
- ☐ CSRF protection enabled on all POST/PUT/DELETE/PATCH routes
- ☐ Input validation schemas applied to all endpoints
- ☐ Rate limiting configured for all endpoints
- ☐ Error handling doesn't expose sensitive data
- ☐ No `console.log` statements with sensitive data
- ☐ No hardcoded secrets in code
- ☐ `.env` file in `.gitignore`

Database Security

- ☐ Production database separate from dev/test
- ☐ Database uses SSL connections
- ☐ Database credentials are strong and unique
- ☐ Connection pooling configured
- ☐ Database backups enabled
- ☐ Database firewall configured (if applicable)

Authentication & Authorization

- ☐ NextAuth properly configured
- ☐ Session cookies are HTTP-only
- ☐ Session cookies use Secure flag (HTTPS)
- ☐ SameSite policy set to 'strict'

- ☐ Strong password requirements enforced
- ☐ Rate limiting on authentication endpoints

Payment Security

- ☐ Stripe LIVE mode keys configured
- ☐ Webhook signature validation enabled
- ☐ Webhook endpoint secured
- ☐ No card data stored in database
- ☐ Payment amount validation implemented
- ☐ Subscription webhook handlers tested

Blockchain Security

- ☐ New production wallet created
- ☐ Private key stored only in environment variables
- ☐ Wallet funded with minimal required amount
- ☐ Smart contract verified on Polygonscan
- ☐ Transaction validation implemented
- ☐ Gas limit protections in place

File Upload Security

- ☐ File type validation (MIME type checking)
- ☐ File size limits enforced (50MB max)
- ☐ Malicious file scanning (if applicable)
- ☐ Secure storage (R2/IPFS)
- ☐ Access control on uploaded files



Security Features Verification

Rate Limiting

- ☐ Rate limiter imported and configured
- ☐ Different limits for different endpoint types:
- ☐ Authentication: 5 requests per 15 minutes
- ☐ NFT Minting: 10 per hour
- ☐ Payments: 20 per hour
- ☐ General API: 60 per minute
- ☐ Rate limit headers included in responses
- ☐ 429 error responses properly formatted
- ☐ Rate limiting tested with multiple requests

CSRF Protection

- ☐ CSRF middleware imported in all routes
- ☐ CSRF tokens generated and validated
- ☐ CSRF token API endpoint (/api/csrf-token) working
- ☐ Client-side CSRF token fetching implemented
- ☐ CSRF tokens in HTTP-only cookies

- ☐ CSRF validation skipped for GET/HEAD requests
- ☐ CSRF errors return 403 status

Input Validation

- ☐ Zod schemas created for all input types
- ☐ Validation applied to all POST/PUT/PATCH endpoints
- ☐ Validation errors return detailed messages
- ☐ Email validation and normalization
- ☐ Wallet address validation
- ☐ URL validation
- ☐ File upload validation
- ☐ XSS prevention through sanitization

Error Handling

- ☐ Centralized error handler used
- ☐ Production errors don't expose sensitive data
- ☐ Error responses include request IDs
- ☐ Prisma errors properly handled
- ☐ Stripe errors properly handled
- ☐ Blockchain errors properly handled
- ☐ 4xx and 5xx errors distinguished
- ☐ Error logging configured



Deployment Steps

1. Vercel Setup

- ☐ Project created/imported in Vercel
- ☐ Production domain configured
- ☐ SSL certificate active (automatic)
- ☐ Build settings configured
- ☐ Deployment regions selected

2. Environment Variables

- ☐ Navigate to Project Settings → Environment Variables
- ☐ Add all 34+ environment variables
- ☐ Select "Production" environment
- ☐ Verify all values are correct
- ☐ Save all variables

3. Initial Deployment

- ☐ Push code to main branch
- ☐ Monitor build logs
- ☐ Check for build errors
- ☐ Verify deployment successful
- ☐ Check deployment URL

4. Post-Deployment Testing

- [] Homepage loads correctly
- [] User registration works
- [] User login works
- [] Wallet connection works
- [] NFT creation works
- [] File uploads work
- [] Payment flow works (test with real card)
- [] Subscription creation works
- [] Webhooks receiving (check Stripe dashboard)
- [] Email notifications sent (if applicable)

Security Testing

Rate Limiting Test

```
# Test authentication rate limit (should block after 5 requests)
for i in {1..10}; do
  curl -X POST https://authichain.com/api/auth/login \
    -H "Content-Type: application/json" \
    -d '{"email": "test@test.com", "password": "wrong"}' \
    -w "\nStatus: %{http_code}\n"
done
```

CSRF Protection Test

```
# Should fail with 403 (no CSRF token)
curl -X POST https://authichain.com/api/subscriptions/create \
  -H "Content-Type: application/json" \
  -d '{"tier": "pro"}' \
  -w "\nStatus: %{http_code}\n"
```

Input Validation Test

```
# Should fail with 400 (invalid data)
curl -X POST https://authichain.com/api/nft/mint \
  -H "Content-Type: application/json" \
  -d '{"name": ""}' \
  -w "\nStatus: %{http_code}\n"
```

Monitoring Setup

Error Monitoring

- [] Sentry account created (recommended)
- [] Sentry DSN configured in environment
- [] Error tracking tested

- ☐ Alert rules configured
- ☐ Team notifications enabled

Performance Monitoring

- ☐ Vercel Analytics enabled
- ☐ Core Web Vitals tracked
- ☐ API route performance monitored
- ☐ Database query performance checked

Uptime Monitoring

- ☐ UptimeRobot or similar configured
- ☐ Health check endpoint created (`/api/health`)
- ☐ Alert contacts configured
- ☐ SMS/Email alerts enabled

Security Monitoring

- ☐ Failed login attempts logged
- ☐ Rate limit violations tracked
- ☐ Unusual activity patterns monitored
- ☐ IP blocking rules configured (if needed)



Incident Response

If Security Issue Detected

1. Assess Severity

- Minor: Automated handling sufficient
- Moderate: Manual investigation required
- Critical: Immediate action needed

2. Immediate Actions (Critical)

- ☐ Pause affected services
- ☐ Rotate compromised secrets
- ☐ Block suspicious IPs
- ☐ Notify team

3. Investigation

- ☐ Review logs
- ☐ Identify attack vector
- ☐ Assess damage
- ☐ Document findings

4. Resolution

- ☐ Patch vulnerability
- ☐ Implement additional protections
- ☐ Test fixes
- ☐ Deploy updates

5. Post-Incident

- ☐ User notification (if data affected)
 - ☐ Post-mortem document
 - ☐ Update security procedures
 - ☐ Additional training (if needed)
-

Regular Maintenance

Weekly Tasks

- ☐ Review error logs
- ☐ Check rate limit violations
- ☐ Monitor failed authentication attempts
- ☐ Review Stripe webhook logs
- ☐ Check database performance

Monthly Tasks

- ☐ Update npm dependencies
- ☐ Review security advisories
- ☐ Check SSL certificate expiry
- ☐ Test backup recovery
- ☐ Review access logs

Quarterly Tasks

- ☐ Security audit
- ☐ Review and update rate limits
- ☐ Rotate API keys (if needed)
- ☐ Update documentation
- ☐ Team security training

Annual Tasks

- ☐ Comprehensive security review
 - ☐ Penetration testing
 - ☐ Rotate all secrets
 - ☐ Review compliance requirements
 - ☐ Update security policies
-

Emergency Contacts

Critical Issues

- **Development Team Lead:** [Contact Info]
- **Security Lead:** [Contact Info]
- **On-Call Developer:** [Contact Info]

Service Providers

- **Vercel Support:** <https://vercel.com/support>
 - **Stripe Support:** <https://support.stripe.com>
 - **Database Provider:** [Provider Support]
-



Quick Reference Links

Documentation

- [Security Hardening Report](#) (./SECURITY_HARDENING_REPORT.md)
- [Vercel Environment Setup](#) (./VERCEL_ENV_SETUP_GUIDE.md)
- [Deployment Guide](#) (./DEPLOYMENT_VERCEL.md)
- [API Documentation](#) (./README.md)

External Resources

- [OWASP Top 10](https://owasp.org/www-project-top-ten/) (<https://owasp.org/www-project-top-ten/>)
- [Next.js Security](https://nextjs.org/docs/going-to-production#security) (<https://nextjs.org/docs/going-to-production#security>)
- [Vercel Security](https://vercel.com/docs/security) (<https://vercel.com/docs/security>)
- [Stripe Security](https://stripe.com/docs/security) (<https://stripe.com/docs/security>)

Code References

- Rate Limiter: `/app/lib/rate-limiter.ts`
 - CSRF Protection: `/app/lib/csrf.ts`
 - Input Validation: `/app/lib/validations.ts`
 - Error Handler: `/app/lib/error-handler.ts`
 - Security Middleware: `/app/lib/security-middleware.ts`
-



Final Pre-Launch Checklist

Day Before Launch

- ☐ All security features tested
- ☐ All environment variables verified
- ☐ Database backup completed
- ☐ Monitoring systems active
- ☐ Emergency contacts verified
- ☐ Rollback plan prepared
- ☐ Team briefed on launch plan

Launch Day

- ☐ Deploy to production
- ☐ Monitor deployment
- ☐ Run smoke tests
- ☐ Verify all critical flows
- ☐ Check monitoring dashboards

- [] Team on standby for issues

First 24 Hours

- [] Monitor error logs continuously
- [] Check performance metrics
- [] Verify payment processing
- [] Monitor user signups
- [] Check webhook deliveries
- [] Review security logs

First Week

- [] Daily error log review
- [] Performance optimization
- [] User feedback collection
- [] Security incident review
- [] Documentation updates

Security Score

Rate your security implementation:

- [] Rate Limiting: 
- [] CSRF Protection: 
- [] Input Validation: 
- [] Error Handling: 
- [] Authentication: 
- [] Authorization: 
- [] Database Security: 
- [] Payment Security: 
- [] Blockchain Security: 
- [] File Upload Security: 
- [] Monitoring: 
- [] Documentation: 

Overall Status: Ready for Production 

Version: 1.0

Last Updated: October 20, 2025

Next Review: Weekly during first month, then monthly